

Segurança de Rede Interna



switches e Vlans

De acordo com a estratégia de defesa em profundidade “segurança em camadas”, precisamos garantir que a rede interna “LAN” da empresa possua barreiras que possam impedir, dificultar e inibir o acesso de ameaças (invasores) aos ativos de TI internos, caso as barreiras de proteção de borda sejam vencidas.

No passado, as conexões locais entre os hosts da rede eram realizadas por meio de dispositivos denominados “HUBs” e repetidores. Estes dispositivos eram extremamente inseguros e não possuíam inteligência para tratar os pacotes de dados que passam por eles. Ou seja, apenas realizam a repetição da transmissão dos pacotes de dados por toda a rede. E, o pior, replicando essa transmissão aos hosts de toda rede. Isso sem dúvida apresentava um risco de segurança enorme, uma vez que uma ameaça poderia ser replicada a todos os hosts da rede.

Atualmente, o envio e recebimento dos pacotes de dados em uma rede local é realizado por roteadores ou switches, que por possuírem uma “inteligência” possibilitam a otimização de todo o tráfego da rede local, realizando a transmissão dos pacotes de dados de forma isolada, host a host sem mais replicar essa transmissão a todos os hosts da rede e, única exclusivamente aquele host que requisitou a transmissão e está autorizado a recebê-la. Esse novo modelo proporcionou uma maior proteção e segurança às redes locais.

Os switches layer 2 e layer 3 são dispositivos computacionais que possuem mecanismos de gerenciamento que podem ser configurados conforme as necessidades de proteção e segurança desenhadas pelas equipes de TI. São conhecidos comumente como switches gerenciáveis de camada 2 ou camada 3 do modelo de arquitetura TCP/IP.

A utilização de switches gerenciáveis como mecanismos de proteção a rede interna possibilita inúmeras vantagens, dentre as quais destacamos: (a) otimização das transmissões dos pacotes de dados por evitar problemas de colisão de dados durante

a transmissão; (b) proteção da transmissão de pacotes de dados entre os hosts conectados à rede, através de um controle de endereçamento físico entre os hosts e as redes conhecido como endereços MAC – Media Access Control, um endereço físico configurado pelo fabricante em um hardware que possui conectividade à rede por meio do protocolo ethernet que fica armazenado em uma tabela denominada tabela ARP no switch que tem como função principal realizar o relacionamento entre o endereçamento IP utilizados junto às aplicações e o endereço físico “MAC” utilizado na camada enlace do modelo de arquitetura TCP/IP; © a criação de redes virtuais denominada VLANs – redes locais virtuais que possibilitam a criação de sub-redes (redes distintas), fortalecendo a proteção e a segurança da rede local, tema que iremos estudar a seguir.

Varadarajan as define como *“estruturas capazes de segmentar, logicamente, uma rede local em diferentes domínios de broadcast”*.

Já Molinari diz que *“uma rede virtual é um grupo de estações e servidores que se comunica independentemente de sua localização física ou topologia, como se fosse um único domínio broadcast, ou uma rede lógica.”*

De acordo com as definições apresentadas, a implantação de VLANs possibilita a partição de uma rede local em diferentes segmentos lógicos (criação de novos domínios broadcast), permitindo que usuários fisicamente distantes (por exemplo, um em cada local ou andar da empresa) estejam conectados à mesma rede.

Como fatores motivadores a criação de VLANs em uma infraestrutura de TI no ambiente corporativo, imagine uma empresa, cujo crescimento acelerado impossibilitou um projeto ordenado de expansão, que possua uma dezena de departamentos conectados a uma rede local interna. Ao contrário do que se pensa, os funcionários de cada departamento estão espalhados pelos andares da sede. Como organizar um domínio para cada setor da empresa? Uma solução possível seria a segmentação da rede interna em redes virtuais, uma para cada departamento. Outro exemplo é a formação de grupos temporários de trabalho. Hoje em dia é comum o desenvolvimento de projetos envolvendo diversos setores de uma empresa, como marketing, vendas, contabilidade e comercial. Durante o período do projeto, a

comunicação entre seus membros tende a ser alta. Para conter o tráfego broadcast, pode-se implementar uma VLAN para este grupo de trabalho.

Os exemplos anteriores mostram que as VLAN proporcionam uma alta flexibilidade a uma rede local. Isto é ideal para ambientes corporativos, onde a todo momento ocorrem mudanças de empregados, reestruturações internas, aumento do número de usuários, entre outras situações. Entre os benefícios proporcionados pela implantação de redes virtuais podemos citar: (a) controle do tráfego broadcast – as VLANs apresentam um desempenho superior às tradicionais redes locais, principalmente devido ao controle do tráfego broadcast. Tempestades de quadros broadcast (*broadcast storms*) podem ser causadas por mau funcionamento de placas de interface de rede, conexões de cabos malfeitas e aplicações ou protocolos que geram este tipo de tráfego, entre outros. Em redes onde o tráfego broadcast é responsável por grande parte do tráfego total, as VLANs reduzem o número de pacotes para endereços desnecessários, aumentando a capacidade de toda a rede. De um outro ponto de vista, em uma rede local segmentada, os domínios de broadcast são menores. Isto porque cada segmento possui um menor número de dispositivos conectados, comparado ao existente na rede sem segmentação. Com isso, trafegam menos quadros broadcast tanto em cada segmento, quanto em toda rede; (b) segmentação lógica da rede – como visto anteriormente, redes virtuais podem ser criadas com base na organização setorial de uma empresa. Cada VLAN pode ser associada a um departamento ou grupo de trabalho, mesmo que seus membros estejam fisicamente distantes. Isto proporciona uma segmentação lógica da rede; (c) redução de custos e facilidade de gerenciamento – grande parte do custo de uma rede se deve ao fato da inclusão e da movimentação de usuários dela. Cada vez que um usuário se movimenta é necessário um novo cabeamento, um novo endereçamento para estação de trabalho e uma nova configuração de repetidores e roteadores.

Em uma VLAN, a adição e movimentação de usuários pode ser feita remotamente pelo administrador da rede (da sua própria estação), sem a necessidade de modificações físicas, proporcionando uma alta flexibilidade; (d) independência da topologia física – VLANs proporcionam independência da topologia física da rede, permitindo que grupos de trabalho, fisicamente diversos, possam ser conectados logicamente a um único domínio broadcast; (e) maior segurança – as redes locais virtuais limitam o tráfego a domínios específicos proporcionando mais proteção e

segurança a estes. O tráfego em uma VLAN não pode ser “escutado” por membros de outra rede virtual, já que estas não se comunicam sem que haja um dispositivo de rede desempenhando a função de roteador entre elas. Desta forma, o acesso a servidores que não estejam na mesma VLAN é restrito, criando assim “*domínios de segurança no acesso a recursos*”.

Proxy

O firewall de aplicação, também conhecido como “proxy de serviços” ou apenas “proxy” é uma solução de proteção que atua como um ponto intermediário entre um host ou uma rede interna e outra rede externa, no geral a internet. No geral, trata-se de um dispositivo “appliance” que possui um hardware com poder de processamento e memória superior, devido ao tratamento que deve ser realizado ao lidar com muitas requisições.

Firewall deste tipo são opções interessantes de segurança porque não permitem a comunicação direta entre origem e destino. Para entender melhor observe a figura a seguir. Perceba que em vez de a rede LAN (interna) se comunicar diretamente com a rede WAN (externa), há um dispositivo (proxy) entre ambas as redes, criando duas conexões – a primeira entre a LAN e o Proxy e, a segunda entre o Proxy e a WAN.

A implementação de um proxy não é tarefa fácil, haja visto a enorme quantidade de serviços e protocolos existentes na internet, fazendo com que, dependendo das circunstâncias, este tipo de firewall não consiga ou exija muito trabalho de configuração para bloquear ou autorizar determinados acessos.

No que diz respeito a limitações, é conveniente mencionar uma solução denominada “proxy transparente”. O proxy “tradicional”, não raramente, exige que determinadas configurações sejam feitas nas ferramentas que utilizam a rede (por exemplo, um navegador de internet) para que a comunicação aconteça sem erros. O problema é que, dependendo da aplicação, este trabalho de ajuste pode ser inviável ou custoso.

O proxy transparente surge como uma alternativa para estes casos porque as máquinas que fazem parte da rede não precisam saber de sua existência, dispensando qualquer configuração específica. Todo acesso é feito normalmente do cliente para a rede externa e vice-versa, mas o proxy transparente consegue interceptá-lo e responder adequadamente, como se a comunicação, de fato, fosse

direta. É válido ressaltar que o proxy transparente também tem lá suas desvantagens, por exemplo: um proxy “normal” é capaz de barrar uma atividade maliciosa, como um malware enviando dados de um host para a internet; o proxy transparente, por sua vez, pode não bloquear este tráfego. Não é difícil entender: para conseguir se comunicar externamente, o malware teria que ser configurado para usar o proxy “normal” e isso geralmente não acontece; no proxy transparente não há esta limitação, portanto, o acesso aconteceria normalmente.

Controlador de Domínio

Para a segurança da informação e segurança cibernética, processos relacionados a autenticação e autorização de usuários a sistemas, serviços ou recursos computacionais dentro e fora de um ambiente organizacional, são fundamentais para a proteção dos ativos de TI. Garantir que apenas usuários confiáveis possam acessar todos os recursos da tecnologia da informação de um ambiente organizacional passa então a ser um ponto de extrema atenção para as equipes de segurança.

Dentro de uma infraestrutura de TI de uma organização, cada computador possui sua própria conta local e essas contas locais não podem ser utilizadas para acessar serviços ou recursos da rede de computadores presente na organização. Afinal é mais seguro que as equipes de TI realizem a administração, configuração e gerenciamento de contas de acesso de usuários de forma centralizada por meio de sistemas do tipo IAM. E, neste contexto é que se encaixam os controladores de domínio ou simplesmente “DCs”.

Em uma infraestrutura de redes de computadores, os domínios são utilizados para agrupar computadores e outros dispositivos na rede a fim de facilitar o monitoramento e gerenciamento e, em cada um desses domínios haverá um controlador de domínios que será utilizado para realizar a autenticação e autorização dos usuários destes computadores, bem como armazenar todas as informações referentes à conta do usuário, privilégios de acesso, registros de login e logoff de forma individual e centralizada.

Para a segurança da informação e segurança cibernética os controladores de domínio são “peças-chaves” na gestão de serviços e recursos de redes a usuários, dentre os controladores de domínios mais populares estão o Microsoft Server – Control Domain

and Active Directory e o SAMBA/LDAP presente nos sistemas operacionais GNU/Linux.

Sniffers

Networks Sniffers ou Farejadores de Redes, são sistemas que tem como função realizar a captura de pacotes de dados que estão sendo transmitidos em uma rede de computadores. Podem também ser nomeados de analisadores de pacotes de dados e, são muito utilizados pelas equipes de redes de computadores, segurança da informação e segurança cibernética para monitorar, detectar e avaliar anomalias nas transmissões de dados, bem como na identificação de pacotes de dados maliciosos que por sua vez podem estar presentes em uma rede de computadores e comprometer assim algum sistema, serviço ou recurso de TI distribuído nesta rede.

Neste contexto, podemos dizer que os sniffers ficam “farejando” a rede e todo o tráfego dela, incluindo sítios visitados, arquivos enviados ou recebidos, acesso a serviços, recursos ou sistemas em tempo real para identificar possíveis tentativas de invasão, roubo ou vazamento de dados, acessos não autorizados, comportamentos estranhos ou não esperados na troca de dados, dentre outros, servido como uma ferramenta e mecanismo de segurança para prevenir eventos ou incidentes de segurança da informação ou cibernética não desejados.

É importante ressaltar que da mesma maneira que um sniffer pode ser utilizado para auxiliar na proteção dos ativos de TI e da rede de computadores de uma organização, ele também pode ser utilizado como um “programa espião” por criminosos cibernéticos para “farejar” o tráfego da rede da organização e com isso possibilitar que o criminoso analise todos os pacotes de dados que estão sendo trocados nessa rede, atrás de informações valiosas tais como: login e senhas de usuários, dados confidenciais, informações contendo arquivos de configuração, etc.

Por fim, dentre os sniffers mais conhecidos, destacam-se: (a) Wireshark; (b) TCPdump; © NetworkMiner; (d) SniffPass e (e) Microsoft Network Monitor.

NOC e SOC

Considerados “peças-chaves” na segurança da informação e segurança cibernética, o NOC – Network Operation Center (Centro de Operações de Rede) e SOC – Security Operation Center (Centro de Operações de Segurança) exercem um papel

importantíssimo para a proteção de todos os ativos de TI e por que não dizer de toda a infraestrutura de TI de uma organização.

Ambos praticamente são similares em diversos aspectos e funções. No entanto, a principal diferença entre eles, os torna únicos nos papéis que desempenham na proteção, mas, com objetivos compartilhados com relação a mesma proteção.

De maneira simplificada, o NOC atua no gerenciamento e monitoramento da rede de computadores da organização, incluindo todos os sistemas, serviços e recursos inclusos nela, realizando atividades tais como: (a) atualização dos ativos de redes; (b) correção de funções, funcionalidades presentes na rede; © monitoramento dos circuitos e links de comunicação de dados; (d) gerenciando e controlando acessos à rede, dentre outros. Já por sua vez o SOC concentra-se no gerenciamento e monitoramento da segurança dos ativos de TI da organização, incluindo a rede de computadores. Com relação às atividades realizadas, destacam-se: (a) o monitoramento e detecção de anomalias e ameaças em tempo real; (b) o gerenciamento de vulnerabilidades dos ativos de TI; © a realização de testes de intrusão para detecção e correção de falhas e vulnerabilidade e, principalmente (d) a resposta a incidentes de segurança, através do acionamento de planos de recuperação de desastres, planos de contingência e de continuidade de negócios.

É importante dizer que o NOC e o SOC são formados por grupos de profissionais da TI que possuem grandes habilidades e conhecimentos com relação a redes de computadores e segurança da informação/segurança cibernética e, operam no esquema 24/7/365, ou seja, 24 horas, 7 dias da semana e 365 dias do ano de forma praticamente ininterrupta.

Em resumo, o NOC tem como missão e objetivo garantir que a rede de computadores e todos os recursos e serviços contidos nela, estejam aptos a operação, enquanto o SOC por sua vez, tem a missão e o objetivo de garantir que todos os ativos de TI, incluindo a rede e seus recursos e serviços, estejam seguros.

Gestão e Monitoramento - SIEM

SIEM é uma combinação de um sistema de gestão de informações de segurança com um sistema de gerenciamento de eventos de segurança e sua principal função é

o de fornecer o monitoramento e análise em tempo real de todos os eventos e registros de dados de segurança para fins de conformidade e auditoria.

Ou seja, o SIEM é um mecanismo de segurança que auxilia as equipes de segurança da informação e segurança cibernética de uma organização a reconhecer potenciais ameaças e vulnerabilidades à segurança antes mesmo delas se tornarem um incidente.

Ao longo da história dos sistemas de informação e tecnologias da informação os SIEMs vêm evoluindo e se tornando mais do que simples ferramentas de gerenciamento de registros e eventos (logs) para sistemas robustos que oferecem as equipes de TI uma análise avançada do comportamento de usuários e entidades dentro do ambiente organizacional através do uso da IA (inteligência artificial) e do aprendizado de máquina para detectar ameaças avançadas, por exemplo, e promover de forma eficiente mecanismos que possibilitem a organização e toda a sua infraestrutura de TI maior segurança e conformidade perante as auditorias de compliance ou a leis e regulamentações impostas por órgãos reguladores.

Com relação aos benefícios obtidos com o SIEM, destacam-se: (a) o reconhecimento de ameaças avançadas em tempo real; (b) auditoria e conformidade regulatória; © centralização de registros (logs) e eventos de segurança em tempo real; (d) detecção de ameaças desconhecidas por meio da IA; e, (e) monitoramento de usuários e sistemas.

Conteúdo Bônus

Complemente seu conhecimento sobre controlador de domínio pesquisando os seguintes temas no site Learn Microsoft:

- Microsoft – Introdução ao AD DS.
- Microsoft – Planejamento e Design do AD DS.

Referência Bibliográfica

CISCO. “**Como funcionam as redes privadas virtuais.**” 13 de outubro de 2008. (6 de novembro de 2019) Disponível em: https://www.cisco.com/c/pt_br/support/docs/security-vpn/ipsec-negotiation-ike-protocols/14106-how-vpn-works.html.

FONTES, E. **Praticando a segurança da informação.** Brasport, 2008.

FREIRE, Alexandre. **Sistemas de Firewall e Defesa de Perímetros.** Portal Módulo Security, 2004.

Guide to Intrusion Detection and Prevention Systems (IDPS). Disponível em: <http://csrc.nist.gov/publications/nistpubs/800-94/SP800-94.pdf>.

HARRIS, Shon. **CISSP All-in-one, 3. ed.:** Mc Graw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento.** Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

Microsoft “**TechNect: protocolos de encapsulamento de VPN.**” 2011. (6 de novembro de 2019) [http://technet.microsoft.com/en-us/library/cc771298\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771298(WS.10).aspx)

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes. 4 ed.** São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

TANENBAUM, Andrew. S. **Redes de Computadores. 4ª ed.** Rio de Janeiro: Editora Campus (Elsevier), 2011.